

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

**Critical 'Linguistic Lumberjack' Flaw in
Fluent Bit Hits Major Cloud Providers**

Date of Publication

May 21, 2024

Admiralty Code

A1

TA Number

TA2024197

Summary

First Seen: April 29, 2024

Affected Product: Fluent Bit

Impact: CVE-2024-4323 is a critical memory corruption vulnerability found in Fluent Bit versions 2.0.7 through 3.0.3. It resides in the embedded HTTP server's parsing of trace requests and can potentially lead to denial of service conditions, information disclosure, or remote code execution.



CVE

CVE	NAME	AFFECTED PRODUCT	ZERO -DAY	CISA KEV	PATCH
CVE-2024-4323	Linguistic Lumberjack (Fluent Bit Memory Corruption Vulnerability)	Fluent Bit	✗	✗	✓

Vulnerability Details

#1

CVE-2024-4323, also known as the "Linguistic Lumberjack" vulnerability, is a critical security flaw identified in Fluent Bit. This vulnerability affects versions 2.0.7 through 3.0.3 of Fluent Bit, it can potentially allow attackers to cause denial of service (DoS), information disclosure, or remote code execution by exploiting the built-in HTTP server's improper handling of trace requests.

#2

Fluent Bit is a widely used logging utility in cloud environments. Fluent Bit, an open-source data collector and processor, handles substantial volumes of log data and is a key component in the infrastructure of major cloud providers like Amazon, Microsoft, and Google.



#3

The vulnerability stems from the way the embedded HTTP server parses trace requests. Specifically, it's likely there's a buffer that holds data from the request that isn't properly sized or validated. A malicious actor could craft a trace request with overflowing data, corrupting memory on the heap and potentially allowing for exploitation.

#4

Even if no traces are configured, any user with access to the API endpoint can still query it. To mitigate potential security threats, users are advised to update to the latest version of Fluent Bit, especially since a proof-of-concept (PoC) exploit for the vulnerability has been released.

Vulnerabilities

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2024-4323	Fluent Bit versions 2.0.7 thru 3.0.3	cpe:2.3:a:fluent_bit:fluent_bit:*:*:*:*:*	CWE-122

Recommendations



Apply Patch: Update Fluent Bit to the latest available version, specifically version 3.0.4 or later, where the vulnerability has been patched. Promptly apply any security updates released by Fluent Bit to stay protected against known vulnerabilities.



Limit Access: If immediate upgrade is not possible, take steps to limit access to the vulnerable endpoints (e.g., /api/v1/traces). This can include configuring firewall rules, using API gateways, or employing authentication and authorization mechanisms to restrict access to authorized users only.



Monitor Activity: Closely monitor your Fluent Bit instances for any suspicious activity that might indicate exploitation attempts.



Engage with Cloud Providers: For organizations using cloud services, reach out to your cloud providers (e.g., Amazon, Microsoft, Google) to confirm that they have applied the necessary updates and mitigations for Fluent Bit.



Vulnerability Scanning: Conduct regular vulnerability scans on your network to identify any potential weaknesses or unpatched software. This proactive approach allows you to address security issues promptly before they can be exploited by attackers.

Potential MITRE ATT&CK TTPs

<u>TA0002</u> Execution	<u>TA0007</u> Discovery	<u>TA0042</u> Resource Development	<u>TA0040</u> Impact
<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities	<u>T1588.005</u> Exploits	<u>T1190</u> Exploit Public-Facing Application
<u>T1499</u> Endpoint Denial of Service	<u>T1082</u> System Information Discovery	<u>T1059</u> Command and Scripting Interpreter	<u>T1059.009</u> Cloud API

Patch Details

Upgrade to Fluent Bit version 3.0.4 or later

Links:

<https://github.com/fluent/fluent-bit/releases/tag/v3.0.4>

<https://github.com/fluent/fluent-bit/actions/runs/9097880110>

References

<https://www.tenable.com/blog/linguistic-lumberjack-attacking-cloud-services-via-logging-endpoints-fluent-bit-cve-2024-4323>

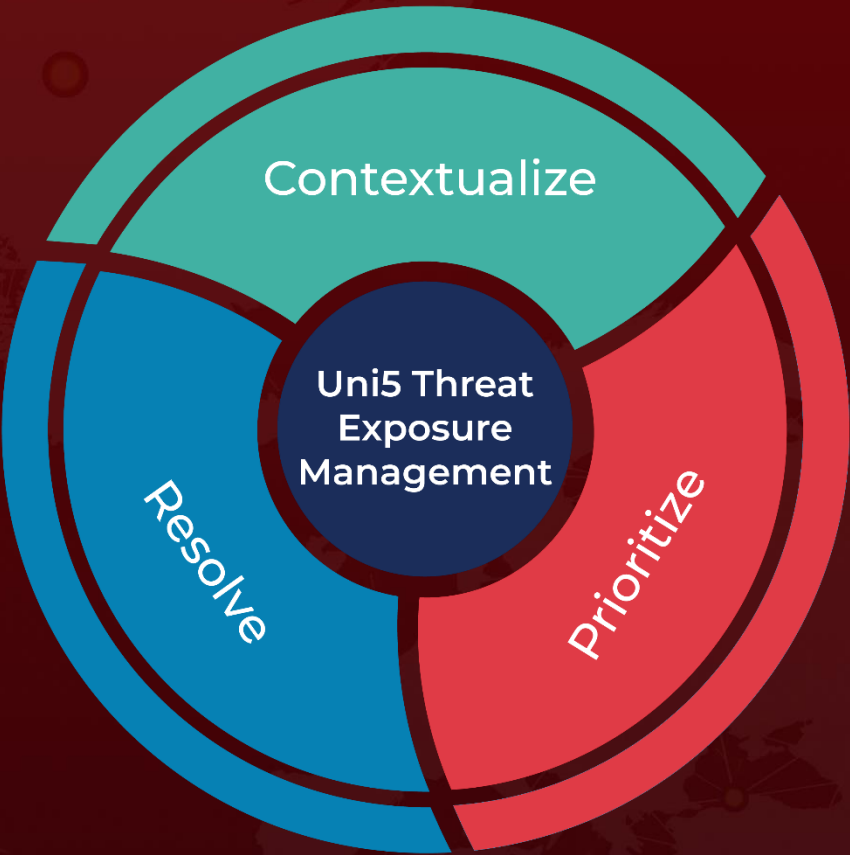
<https://www.tenable.com/security/research/tra-2024-17>

<https://github.com/skilfoy/CVE-2024-4323-Exploit-POC>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
May 21, 2024 • 5:30 AM

